

REDES Y SEGURIDAD 2

PRÁCTICA 2.2



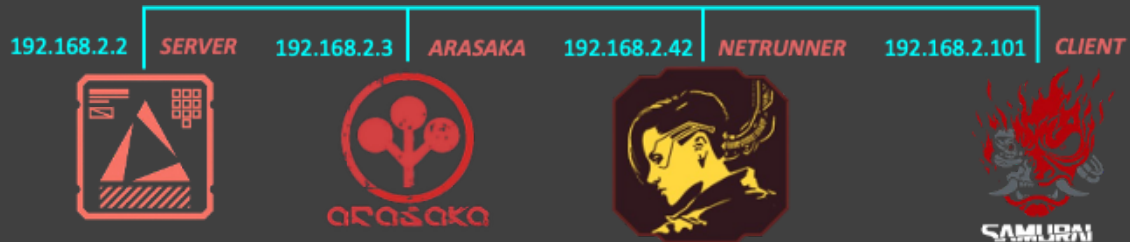
JOHNNY: ¿Una biblioteca? Ja... Nunca fui de leer. Pero resulta que los servidores DNS funcionan como esto: un sitio donde las máquinas vienen a preguntar dónde encontrar lo que buscan. El problema es que alguien puede hacerse pasar por el bibliotecario y enviarte directo a una trampa. En esta práctica vas a jugar

sucio: manipular respuestas, redirigir a incautos... y luego descubrir cómo evitar que lo hagan contigo. DNSSEC es como ponerle candado a la estantería correcta. Y sí, sé que suena aburrido. Pero si no entiendes esto, acabarás navegando en un mar de mentiras. Y créeme... ya hay demasiadas.

En esta práctica aprenderás a:

- Desplegar un servidor DNS básico y realizar un ataque MitM para este protocolo.
- Entender la importancia de DNSSEC y desplegar una contramedida al ataque MitM DNS con Unbound.

CHAMBA: P22-dns



Las máquinas (**server**, **arasaka**, **netrunner** y **client**) ya tienen su IP asignada y están listas para trabajar sobre ellas.

DESPLIEGUE DE UN SERVIDOR DNS

Se procederá a desplegar un servidor DNS en **server** que traducirá el dominio **arasaka.nightcity** como **192.168.2.3** (**arasaka**).

SERVER

Editar el fichero de configuración **/etc/bind/named.conf.options** y añadir el siguiente contenido al final del mismo, pero antes del último **};**:

```
listen-on {  
  
    192.168.2.0/24;
```

SERVER

```
};

allow-query { any; };

forwarders {

    DNS_PRIMARIO;

    DNS_SECUNDARIO;

};
```

Los valores de *DNS_PRIMARIO* y *DNS_SECUNDARIO* dependerán de la red física real en la que se realice esta práctica.

- 147.96.1.9 y 147.96.2.4, si es en la UCM.
- 8.8.8.8 y 8.8.4.4, si es en cualquier otro lugar (que no tenga limitado el acceso a los servidores DNS de Google).

Los **forwarders** permitirán preguntar por dominios no gestionados por **server**.

Siempre en el mismo fichero, añadir la información relativa a la zona **arasaka.nightcity**, esta vez después del último **};**:

```
zone "arasaka.nightcity" {

    type master;

    file "/etc/bind/zones/db.arasaka.nightcity";

};
```

SERVER

Crear un directorio llamado **/etc/bind/zones**.

Dentro, editar un fichero nuevo llamado **db.arasaka.nightcity** y añadir el siguiente contenido:

```
$TTL 604800

@      IN      SOA      ns.arasaka.nightcity. admin.arasaka.nightcity. (
                               2          ; Serial
                               604800     ; Refresh
                               86400      ; Retry
                               2419200    ; Expire
                               604800 )   ; Negative Cache TTL
;

@      IN      NS       ns.arasaka.nightcity.
ns     IN      A        192.168.2.2 ; servidor DNS (esta máquina)
@      IN      A        192.168.2.3 ; arasaka.nightcity apunta a esta IP
```

Verificar la configuración general y de la zona. No deberá devolver ningún error.

> named-checkconf

**> named-checkzone arasaka.nightcity
/etc/bind/zones/db.arasaka.nightcity**

CLIENT

Editar el fichero de configuración **/etc/resolv.conf**, indicando que el servidor DNS (**nameserver**) ahora es la IP de **server**.

Usando el comando **dig**, obtener información de un dominio existente (por ejemplo, **ucm.es**). Hacer lo mismo con **arasaka.nightcity**. Anotar el dato relativo al servidor al que se hace la petición (**SERVER**).



¿En qué puerto está escuchando el servidor DNS?

¿Qué protocolo de transporte utiliza?

SUPLANTACIÓN DEL SERVIDOR DNS

Se realizará un ataque MitM en el que **client** se conectará a un servidor FTP desplegado en **netrunner**, creyendo que lo está haciendo en

arasaka.nightcity (**arasaka**). Para ello se falsificarán las respuestas a las peticiones DNS realizadas por **client**.

Para interpretarlas, se realizará previamente un ataque MitM mediante ARP spoofing, ya que se encuentran ambas máquinas en la misma red. Este ataque será doble, ya que **netrunner** suplantarán a **server** ante **client**, y a **client** ante **server**.

Finalmente, se usará **iptables** para bloquear las respuestas legítimas del servidor DNS (**server**), para así garantizar que a **client** sólo lleguen las que forman parte del ataque de DNS spoofing.

CLIENT

Conectarse al servidor FTP de **arasaka.nightcity** con el comando **ftp**. El usuario es **anonymous** y la contraseña, una dirección de correo electrónico inventada.

Una vez dentro, desconectarse.



¿Por qué se pide un correo electrónico al entrar como **anonymous**?

DESPLIEGUE DEL SERVIDOR FTP FALSO

NETRUNNER

Editar el fichero de configuración de vsFTP (**/etc/vsftpd.conf**).

- Se deben permitir los accesos anónimos (**anonymous_enable**).
- Se deben deshabilitar los accesos locales (**local_enable**). Esta línea se puede comentar directamente.
- Cambiar el mensaje de bienvenida (**ftpd_banner**) por algo que permita hacer pasar este servidor FTP por el legítimo (Ejemplos: "ARASAKA: La seguridad es la ley suprema.", "Este es el verdadero servidor FTP, confía.").

Iniciar el servidor FTP (**vsftpd**) utilizando el comando **service**.

Probar la conexión con el servidor FTP recién desplegado.

Nuevamente, el usuario es **anonymous** y la contraseña, una dirección de correo electrónico inventada.

ATAQUE DNS SPOOFING

NETRUNNER

En la primera fase, se deberá realizar el ataque doble de ARP spoofing. Como recordatorio:

- Realizar las funciones de router con **fragrouter**.
- Con **arp spoof**, indicarle a **client** que **netrunner** es **server**.
- Con **arp spoof**, indicarle a **server** que **netrunner** es **client**.

Para evitar entrar en competencia con el servidor DNS legítimo (**server**), se usará **iptables** para bloquear sus respuestas legítimas. Basta con una línea y como recordatorio:

- Se realizará **DROP** en la cadena **FORWARD**.
- El origen será **server** y el destino, **client**.
- El protocolo de transporte y el puerto es el de DNS.

En la segunda fase, arrancar **bettercap** indicando el interfaz de red que se usará.

> **bettercap -iface eth0**

Dentro del entorno de **bettercap** se seguirán los siguientes pasos:

1. Escanear la red local.

> **net.probe on**

NETRUNNER

Si devuelve fallo (habitualmente por no encontrar la dirección MAC del gateway) se recomienda reiniciar **bettercap**.

2. Una vez estén registradas las 3 máquinas desplegadas más el gateway, interrumpir el escaneo y mostrar los resultados.

> **net.probe off**

> **net.show**

3. Indicar los datos del DNS spoofing (que **arasaka.nightcity** apunte a **netrunner**).

> **set dns.spoof.domains arasaka.nightcity**

> **set dns.spoof.address 192.168.2.42**

4. Activar el DNS spoofing.

> **dns.spoof on**

5. Activar el sniffer de **bettercap**.

> **net.sniff on**

CLIENT

Obtener información de **arasaka.nightcity** usando el comando **dig**.
Conectarse al servidor FTP de **arasaka.nightcity**.



Anímate a suplantar otros dominios como **informatica.ucm.es** o...
¡qué demonios! ¡todos los de **ucm.es**!

Recuerda, "fines académicos" (y sólo en un entorno virtual).

PROTECCIÓN DE DOMINIOS CON DNSSEC

NETRUNNER

Interrumpir la el DNS spoofing con **bettercap**.

> **dns.spoof off**

El comando anterior se debe introducir en el entorno de **bettercap**.

Eliminar la regla de **iptables** que bloquea las respuestas del servidor DNS legítimo (**server**). Para ello, se puede vaciar la tabla directamente (**-F**).

CLIENT

Hacer una petición **dig** con la opción **+dnssec** para el dominio **nato.int**.

Debería aparecer un registro llamado **RRSIG**, el cual es la firma digital DNSSEC para ese dominio.

NETRUNNER

Ahora **nato.int** es el dominio que debe apuntar a **netrunner**.

Reanudar el ataque DNS Spoofing con **bettercap** y la regla de **iptables**.

CLIENT

Hacer la misma petición **dig** con la opción **+dnssec** a **nato.int**.



Con el comando **dig** se puede indicar el servidor DNS al que realizar la consulta con la opción **@SERVIDOR_DNS**.



¿Qué diferencias se aprecian en ambas consultas realizadas?



La siguiente parte de la práctica podría no funcionar en el laboratorio debido a la configuración de red de la UCM. Consulta con el profesor sobre cómo proceder.

AUTOPROTECCIÓN CON UNBOUND

Unbound es un resolutor local, que tiene 2 modos de trabajo:

1. Pregunta directamente a los servidores raíz (resolver recursivo completo).
2. Reenvía la petición a otro resolutor (resolver reenviador).

Como **client** está sufriendo un ataque MitM local, se desplegará la primera solución.

NETRUNNER

Pausar el ataque MitM. Bastará con eliminar la regla de **iptables** que se ha introducido anteriormente.

CLIENT

Editar **/etc/unbound/unbound.conf.d/dnssec.conf** con el siguiente contenido:

server:

```
interface: 127.0.0.1

access-control: 127.0.0.0/8 allow

verbosity: 1

root-hints: "/var/lib/unbound/root.hints"

auto-trust-anchor-file: "/var/lib/unbound/root.key"

val-permissive-mode: yes

module-config: "validator iterator"
```

Descargar el fichero de servidores raíz de DNS, localizado en **<https://www.internic.net/domain/named.root>** y guardarlo como **/var/lib/unbound/root.hints**. Inspeccionar su contenido.

CLIENT

Crear el fichero **/var/lib/unbound/root.key** y escribir el siguiente contenido, que se corresponde con la *DNSSEC root key*:

```
. 3600000 IN DNSKEY 257 3 8 (  
AwEAAa96jeuknZlaeSrvyAJj6ZHv28hhOKlx3rLGXVaC6rXTsDc449/cidltppyGwCJNn0AIFNKF2jBosZBU  
5eeHspaQW0mDElZsjlCMQMC3aeHbGiShvZsx4wMYSjH8e7Vrhbu6irwCzVBApESjbUdpWWmEnhathW  
u1jo+siFUiRAAxm9qyJNg/w0ZqqzL/dL/q8PkcRU5oUKEpUge71M3ej2/7CPqpdVwuMoTvoB+ZOT4YeGy  
xMvHmbrxlfzG0H0ijtzn+u1TQNatX2XBuzZNQ1K+s2CXkPIZo7s6JgZyvaBevYtxPvYlW4z9mR7K2vaF18U  
YH9Z9GNUUeayffKC73PYc=  
)
```



La *DNSSEC root key* se ha extraído del siguiente fichero:
<https://data.iana.org/root-anchors/root-anchors.xml>.

CLIENT

Comprobar la configuración con **unbound-checkconf**.

Reiniciar el servicio **unbound** con el comando **service**.

Como **unbound** levanta un servidor DNS local, hay que actualizar el fichero **/etc/resolv.conf**.

Ahora **nameserver** debe apuntar a 127.0.0.1.

Volver a realizar la consulta **dig** anterior con la opción **+dnssec**.



El comando **unbound-control lookup DOMINIO** permite realizar un análisis más exhaustivo.

_ EOL



Si lo de "que inventen otros" no es para ti... imárcate un servidor
DNSSEC en **server!**